



MERIDIAN TRUST BANK SECURITY ASSESSMENT

Vulnerability Triage to Incident Response

Carter Yanosick

Cybersecurity for Professionals Bootcamp

Week 6, Days 1–3 — Hands-On Lab

Case MTB-IR-2026-0902

September 2026

Executive Summary

This review assessed five servers, including an internet-facing customer portal and a domain controller. An application server was found running file transfer software with a known backdoor, and the domain controller had not been patched against an actively exploited flaw. Three additional Critical-severity findings reported by the scanner were investigated and confirmed as false positives during manual validation.

Six days after this assessment was delivered, the customer portal (MTB-WEB01) was compromised through the exact vulnerability this report ranked as the highest real-world priority. This document presents both the original vulnerability assessment and the subsequent incident response investigation as a single continuous body of evidence.

Nothing in the intrusion described in Section 5 was a zero-day. Every vulnerability the attacker used had already been identified, validated, and prioritized in Section 4 six days earlier — and it was the threat-intelligence cross-reference, not the raw CVSS score, that correctly flagged the entry-point vulnerability as the top risk.

1. Scope and Method

This assessment covered five hosts: the customer-facing web portal (MTB-WEB01), the application/file-transfer server (MTB-APP01), the internal file server (MTB-FILE01), the domain controller (MTB-DC01), and a non-production test application (MTB-DVWA01). An authenticated vulnerability scan ran against all five hosts on 8 September 2026, producing 37 findings.

Findings were validated by comparing the scanner's detected software version against the affected-version range published on NIST's National Vulnerability Database (NVD); configuration findings with no CVE were instead validated against evidence pulled directly from each host. Validated findings were then cross-referenced against CISA's Known Exploited Vulnerabilities (KEV) catalog to identify which represent confirmed real-world threats, and re-prioritized accordingly.

1.1 Environment Assessed

Host	Address	Role	Notes
MTB-WEB01	10.50.2.24	Customer portal web server	DMZ, internet-facing, high criticality
MTB-APP01	10.50.2.25	Application and file transfer	Legacy FTP still in use
MTB-FILE01	10.50.2.26	Internal file server	Legacy protocols still enabled
MTB-DC01	10.50.2.10	Windows domain controller	Authenticated scan credentials supplied
MTB-DVWA01	10.50.2.30	Test web application	Non-production, deliberately weak

1.2 Tools and Methodology

Tool	Purpose
CyberChef	Extracting IOCs from logs, decoding a Base64 payload, SHA-256 hash verification, and defanging indicators
NVD (nvd.nist.gov)	Confirming the actual affected-version range for each CVE, used to validate or disprove scanner findings
CISA KEV Catalog	Cross-referencing validated findings against confirmed real-world exploitation
Spreadsheet	Findings tracking, validation table, KEV cross-reference, timeline, and IOC list

2. Vulnerability Assessment Findings

2.1 Severity Overview

Severity	Count
Critical	6
High	10
Medium	12
Low	5
Info	4
Total	37

Ranked by CVSS alone, the top ten findings placed four different Critical (9.8) findings at the top of the remediation queue. Manual validation against NVD's published affected-version ranges disproved three of those four.

2.2 Prioritized Findings

Rank	Host / Finding	Evidence	Recommended Fix
1	MTB-DC01 — MTB-0025CVE-2020-1472(Zerologon)	Detected: Windows Server 2019, last cumulative update applied 2020-06-09 (PowerShell Get-HotFix). NVD: affects Windows Server 2008 R2 through 2019 where the August 2020 update has not been applied. Confirmed in CISA's KEV catalog (added 2021-11-03) — actively exploited in the wild.	Apply the August 2020 cumulative security update (and all subsequent updates) to MTB-DC01 immediately. Enforce Secure RPC for Netlogon per Microsoft's ZeroLogon remediation guidance once patched.
2	MTB-APP01 — MTB-0009CVE-2011-2523(vsfptd Backdoor)	Detected: vsftpd 2.3.4, confirmed via banner grab (nc) and dpkg -I. This exact build corresponds to the compromised source tarball distributed by attackers between 30 June and 3 July 2011. Not present in the KEV catalog.	Uninstall vsftpd 2.3.4 and reinstall from the official, verified repository at a current supported version. Audit MTB-APP01 for signs of prior compromise, since this build has historically shipped with an active backdoor.

2.3 Re-Prioritized Ranking (Threat Intelligence Applied)

Rank	Finding	Host	CVSS	In KEV?
1	MTB-0001 — Apache Path Traversal & RCE (CVE-2021-42013)	MTB-WEB01	9.8	Yes
2	MTB-0025 — Zerologon (CVE-2020-1472)	MTB-DC01	8.8	Yes
3	MTB-0003 — PwnKit / pkexec (CVE-2021-4034)	MTB-WEB01	7.8	Yes



Rank	Finding	Host	CVSS	In KEV?
4	MTB-0019 — PwnKit / pkexec (CVE-2021-4034)	MTB-FILE01	7.8	Yes
5	MTB-0002 — Apache Path Traversal (CVE-2021-41773)	MTB-WEB01	7.5	Yes
6	MTB-0014 — glibc Buffer Overflow (CVE-2023-4911)	MTB-APP01	6.5	Yes
7	MTB-0009 — vsftpd Backdoor (CVE-2011-2523)	MTB-APP01	9.8	No
8	MTB-0004 — jQuery XSS (CVE-2020-11022)	MTB-WEB01	6.1	No

2.4 False Positives

All three of the following were also present in the CISA KEV catalog for other, unrelated CVEs — meaning a team that skipped validation would have spent a remediation cycle patching software that was never vulnerable, while a genuinely exploited, lower-CVSS finding (ZeroLogon) sat further down the raw-CVSS list.

Finding	Scanner Claimed	What We Proved, and the Evidence
MTB-0012CVE-2014-6271(Shellshock)	Critical (9.8) RCE via Bash on MTB-APP01. Also listed in KEV (added 2022-01-28).	False positive. NVD states the flaw affects GNU Bash through version 4.3. MTB-APP01 runs Bash 5.1.16 — nearly seven major versions past the affected range. The scanner matched on the presence of a Bash banner, not the installed version.
MTB-0016CVE-2017-7494(SambaCry)	Critical (9.8) RCE via Samba on MTB-FILE01. Also listed in KEV (added 2023-03-30).	False positive. NVD states the flaw affects Samba 3.5.0 up to (not including) 4.6.4. MTB-FILE01 runs Samba 4.15.13 — nine minor versions past the highest affected release.
MTB-0024CVE-2019-0708(BlueKeep)	Critical (9.8) RCE via RDP on MTB-DC01. Also listed in KEV (added 2021-11-03).	False positive. NVD states the flaw affects Windows XP through Windows Server 2008 R2. MTB-DC01 runs Windows Server 2019 — a generation newer than anything this CVE applies to.

2.5 Compensating Controls

MTB-DC01 is a production domain controller; applying the required cumulative update needs a scheduled maintenance window that cannot happen immediately. Until the patch is applied:

Control
Restrict Netlogon secure channel connections to only known, approved member servers via a firewall/network ACL, so it is not reachable from unrelated network zones.
Enable Netlogon event logging (Event ID 5829) to alert on any vulnerable connection attempt, so an exploitation attempt is visible even before the patch lands.
Record a dated commitment to apply the patch within 5 business days, with a named owner, so the control does not quietly become permanent.

2.6 Recommended Scan Cadence

Monthly authenticated scans for internet-facing and high-criticality hosts (MTB-WEB01, MTB-DC01), and quarterly scans for internal, lower-exposure hosts (MTB-APP01, MTB-FILE01). The internet-facing and identity infrastructure face a larger amount of threat than internal systems; scanning the higher-risk targets more frequently is intended to improve proactive detection.

3. Incident Response: Root Cause Investigation

Six days after the assessment above was delivered, MTB-WEB01 triggered a SOC alert for a periodic outbound connection to a non-allowlisted destination. The host was isolated at the network layer but deliberately left powered on, so that volatile evidence — running processes, network state, open file handles — would not be lost before it could be captured.

Why the host was left powered on

Imaging the disk first and powering off would have produced a technically clean disk image of an incident that could no longer be fully explained. Volatile evidence was captured in order of volatility (memory/process state → network state → running system state) before the disk was imaged.

3.1 Evidence Handling and Chain of Custody

CHAIN OF CUSTODY - CASE MTB-IR-2026-0902

```
Case           : MTB-IR-2026-0902
Affected asset  : MTB-WEB01 (10.50.2.24), DMZ customer portal
Alert received  : 2026-09-02 09:47 UTC
Host isolated   : 2026-09-02 10:05 UTC (network ACL, host left powered on)
Volatile capture: 2026-09-02 10:12 - 10:14 UTC
Disk acquired   : 2026-09-02 10:31 UTC
Acquired by    : Meridian Trust Bank IR Team
Media          : /dev/sda, 1 GB, MBR, single ext4 partition
```

Four key artifacts were hashed (SHA-256) at acquisition to prove they were not altered afterward:

Artifact	SHA-256
/var/www/html/uploads/style.php	2dfc22e2fb93187b7537d9ffec52ecc94fd6416c84b78e68ff7a025e975c20c
/usr/local/bin/apache-worker	1ebcce99569f4337f9ee3746b7b095a9f54abfe3036ef06014b1a00ea4d15d4b
/etc/cron.d/apache-logrotate	d9bc0ee387921dcaedfc87de4a72ec42e45cf268adb2777d5b014375417cb9cc
/etc/passwd	0243860670744531f70b46cfb844a66eb8ca0de0e4b7b15dff991b3960577295

This acquisition-and-verification workflow was independently reproduced in CyberChef (SHA-256), then a single character of a test value was changed to confirm the hash changed completely and unpredictably — demonstrating why a hash recorded at acquisition is sufficient, on its own, to prove evidence has not been tampered with later.

3.2 Incident Timeline

Correlating file-system timestamps, Apache access/auth logs, and the volatile captures produced a single merged timeline of the intrusion, each entry marked by evidence strength.

Time (UTC)	Event	Evidence Source	Confidence
02:08:14	Reconnaissance scan of MTB-WEB01 root path from attacker IP	access.log	Inferred
02:12:33	Path-traversal exploitation of CVE-2021-42013	access.log	Inferred
02:15:22	Web shell (style.php) uploaded	access.log, timeline	Confirmed
02:17:40	Web shell invoked	access.log	Inferred
02:20:47	Privilege escalation via PwnKit (CVE-2021-4034)	auth.log	Inferred
02:23:11	Backdoor account svc-backup (UID 0) created	auth.log	Inferred
02:24:48	Attacker SSHes in directly as root using a planted key from 185.220.101[.]47	Capture 3, auth.log	Confirmed
02:25:57	C2 beacon binary apache-worker written to /usr/local/bin	timeline	Inferred
02:26:30	Cron persistence installed to relaunch the beacon every 5 minutes	syslog reload, timeline	Confirmed
02:34:55	Customer data staged to /tmp/.ICE-unix	timeline	Inferred
02:41:19	Attacker's root session activity written to .bash_history	timeline	Inferred
09:47:12	SOC alert fires on the beaconing pattern and unrecognized root process	alert record	Inferred

The beacon had been calling out for roughly 7.5 hours before it was detected — and only then because it was noisy and predictable on a fixed interval. A quieter beacon would likely still be running.

3.3 Root Cause

The compromise traces back to the exact finding this assessment ranked #1 after threat-intelligence cross-referencing: MTB-0001, CVE-2021-42013 (Apache HTTP Server path traversal / RCE), enabled by an Apache configuration that scoped `<Directory />` with `Require all granted` instead of restricting it to the web root, combined with an active `ScriptAlias /cgi-bin/`. This gave the attacker their initial foothold.

From there, MTB-0003, CVE-2021-4034 (PwnKit / pkexec) — also on the prioritized findings list in Section 2.3 — carried the attacker from the unprivileged `www-data` account to root:

```
Sep 2 02:20:47 mtb-web01 pkexec[1207]: pam_unix(polkit-1:session): session opened
for user root(uid=0) by (uid=33)
Sep 2 02:21:05 mtb-web01 pkexec[1207]: www-data: Executing command [USER=root]
[TTY=unknown] [CWD=/var/www/html/uploads] [COMMAND=/bin/sh]
```

3.4 Persistence Mechanisms

Mechanism	Survives	Detection Recommendation
svc-backup local account (UID 0)	Password resets, process kills — it is an independent login identity	Alert on any useradd assigned UID 0
Planted SSH key in <code>/root/.ssh/authorized_keys</code>	Password changes on other accounts — key-based auth bypasses them	File-integrity monitoring on <code>/root/.ssh</code> , <code>/etc/passwd</code> , <code>/etc/shadow</code> , <code>/etc/group</code>
<code>/etc/cron.d/apache-logrotate</code> (disguised as routine log rotation)	Reboots — cron relaunches the beacon on schedule	File-integrity monitoring on <code>/etc/cron.*</code>

3.5 Consolidated Indicators of Compromise

Defanged for safe circulation.

Type	Indicator	Detects
Network	185.220.101[.]47	Attacker source address / root SSH login
Network	185.220.101[.]47:8443	C2 beacon channel
File path	/var/www/html/uploads/style.php	Web shell dropped via the path-traversal exploit
File path	/usr/local/bin/apache-worker	C2 beacon disguised as a legitimate Apache process
File hash (SHA-256)	2dfc22e2f...e975c20c	Exact match for this web shell
File hash (SHA-256)	1ebcce995...ea4d15d4b	Exact match for this C2 beacon
Account	svc-backup (local, UID 0 / GID 0)	Backdoor account with root privileges
Persistence	/etc/cron.d/apache-logrotate	Task persistence disguised as routine logging

3.6 Prevention and Detection Recommendations

Category	Recommendation
Patching	Upgrade Apache to 2.4.51+. Upgrade policykit-1 to the vendor-patched build that closes CVE-2021-4034.
Configuration	Remove the blanket "Require all granted" from the root directory scope. Remove ScriptAlias /cgi-bin/ if CGI execution is not required.
Detection	File-integrity monitoring on /etc/passwd, /etc/shadow, /etc/group, /root/.ssh, and /etc/cron.*. Alert on any useradd assigned UID 0. Egress-filter outbound connections to non-allowlisted destinations, which would have blocked the C2 beacon outright.

4. Key Takeaways

Manual validation caught three Critical-severity scanner findings that were false positives — each one matched on a service's presence, not its actual version. Left unvalidated, all three would have consumed a remediation cycle on vulnerabilities that were never exploitable, while a genuinely exploited, lower-CVSS finding (ZeroLogon) sat further down the raw-CVSS list. CVSS measures how bad a vulnerability would be if exploited; it says nothing about whether anyone is actually exploiting it — which is exactly why the KEV cross-reference changed the priority order, and why the vulnerability it identified as the top real-world risk was the same one used in the actual compromise six days later.

The Day 3 investigation reinforced why evidence order-of-volatility is not a formality: imaging the disk before capturing running processes and network state would have permanently destroyed the only proof that the beacon was active and connected, leaving nothing but static files to reason from. The attacker also cleared root's own shell history but left a second account's history file at zero bytes instead — a reminder that any single evidence source can be defeated, but corroborating sources close that gap. And ultimately, removing the backdoor account and the beacon treats the symptom; without fixing the misconfiguration and unpatched pkexec that gave the attacker their foothold in the first place, the same intrusion could happen again immediately.

Skills Demonstrated

Vulnerability scan triage and manual validation against authoritative sources (NVD); differentiating CVSS severity from real-world exploitation risk using threat intelligence (CISA KEV); false-positive and true-positive analysis with documented evidence; compensating-control design for vulnerabilities that cannot be patched immediately; order-of-volatility-compliant evidence preservation; cryptographic hash verification of forensic evidence; file-system timeline (MACB) reconstruction and analysis; log correlation across web, authentication, and system logs; privilege-escalation and persistence-mechanism identification; IOC extraction, consolidation, and defanging; and root-cause analysis connecting a vulnerability assessment directly to a live incident.